

Governance für AI Agents

Regeln für den Einsatz von AI Agents in Kundenprojekten,
Forschung und Programmierung bei Digital Humanities Craft

Beschlussvorlage, Version 1.0 vom 5. November 2026
Gilt nach Beschluss durch die Eigentümer
Gestützt auf Quellen aus dem Jahr 2026

Diese Governance regelt, wie Digital Humanities Craft (DHCraft) AI Agents in Kundenprojekten, in der Forschung und beim Programmieren einsetzt. Ein AI Agent ist hier ein System auf Basis eines Large Language Model (LLM), das mehrschrittige Aufgaben mit Werkzeugen wie Shell, Browser, Dateien oder Mail selbstständig plant und ausführt. Die Governance gilt für alle, die für DHCraft mit Agents arbeiten, also für die beiden Eigentümer und für freie Mitarbeitende.

DHCraft ist ein Unternehmen mit zwei Personen in Graz. Es entwickelt Forschungssoftware und digitale Editionen, berät und schult zu generativer KI und arbeitet als technischer Partner in Drittmittelprojekten. Agents arbeiten dabei vor allem mit geisteswissenschaftlichen Forschungsdaten, oft mit gemeinfreien oder frei nutzbaren Objekten. Personenbezogene Daten kommen nur selten vor. Die Regeln für sie und für besonders geschützte Daten gelten für diese Fälle.

Jede Regel nennt ihren Status und ihre Quellen in der Wissensbasis mit Seite. Die Status sind unten erklärt. Die rechtlichen Einschätzungen in dieser Governance sind keine Rechtsberatung.

Pflicht	folgt aus dem Gesetz
Vorgabe	folgt aus den Regeln eines Förderers
Empfehlung	Leitlinie einer Behörde, nicht bindend
Ableitung	Folgerung, die DHCraft aus den Quellen zieht

1 Grundsätze

Empfehlung	Die Verantwortung für alles, was ein Agent tut oder erzeugt, bleibt bei der Person, die ihn einsetzt. Der Einsatz eines Agents gilt nie als Übertragung von Kontrolle oder Verantwortung. [1] S. 7, 8
Empfehlung	Ein Agent erhält so viel Selbstständigkeit, wie das Risiko der Aufgabe zulässt. Je mehr er selbst entscheidet, desto größer ist der mögliche Schaden eines Fehlers. [2]
Empfehlung	Ein Agent erhält nur die Zugänge, die seine aktuelle Aufgabe braucht, und nie einen breiten oder unbeschränkten Zugriff. [3] S. 4, 7
Pflicht	Die DSGVO gilt neben dem AI Act und wird von ihm nicht verdrängt. Der AI Act ist keine Rechtsgrundlage für eine Datenverarbeitung. [4] S. 3, 4

2 Rollen und Verantwortung

Empfehlung Die Eigentümer benennen eine Person, die für den Einsatz von Agents bei DHCraft verantwortlich ist. Sie führt das Werkzeugregister, gibt neue Werkzeuge frei und ist Ansprechperson bei Vorfällen.

[2]

Empfehlung Zur Governance gehört eine Person, die den Datenschutz und die konkreten Verarbeitungen kennt. Bei DHCraft kann das eine der beiden Personen sein oder eine externe Beratung. Ob daraus eine formelle Bestellung als Datenschutzbeauftragte Person werden muss, regelt der folgende Abschnitt.

[5] S. 52

Pflicht DHCraft ist im Sinne des AI Act Betreiber jedes Agents, den es beruflich nutzt. Freie Mitarbeitende, die in seinem Auftrag arbeiten, ändern daran nichts.

[6] S. 7, 9

Pflicht Baut DHCraft einen Agent, der unter eigenem Namen in Betrieb geht, ist DHCraft sein Anbieter. Lässt ein Kunde den Agent entwickeln und betreibt ihn unter seinem Namen, ist der Kunde Anbieter. Der Vertrag hält diese Rolle fest.

[6] S. 6

Datenschutzbeauftragte Person

Pflicht Eine Datenschutzbeauftragte Person ist Pflicht für Behörden und für Verantwortliche und Auftragsverarbeiter, deren Kerntätigkeit in der umfangreichen, regelmäßigen und systematischen Überwachung von Personen besteht oder in der umfangreichen Verarbeitung besonders geschützter Daten nach Art. 9 DSGVO. Die Pflicht gilt auch für Auftragsverarbeiter wie DHCraft, und sie folgt nicht automatisch daraus, dass ein Kunde selbst eine solche Person bestellen muss.

[7] Art. 37 Abs. 1; [8] S. 9

Kerntätigkeiten sind die Haupttätigkeiten eines Unternehmens. Datenverarbeitung als Nebentätigkeit zählt nicht. Die Leitlinien der Datenschutzbehörden nennen Lohnabrechnung und gewöhnlichen IT-Support als Beispiele für Nebentätigkeiten.

[7] Erwägungsgrund 97; [8] S. 7

Für „umfangreich“ gibt es keine Schwelle. Maßgeblich sind die Zahl der Betroffenen, die Menge und Art der Daten, die Dauer und die räumliche Reichweite. Die Patientendaten einer einzelnen Ärztin gelten als nicht umfangreich, und dazwischen liegt eine Grauzone.

[8] S. 7–8

	Das österreichische Datenschutzgesetz begründet für private Unternehmen keine zusätzliche Pflicht. Es regelt die Verschwiegenheit einer bestellten Person, und die Bestellpflicht in § 57 gilt nur für Sicherheits- und Strafverfolgungsbehörden. [9] § 5 und § 36 Abs. 1
Ableitung	Für DHCraft folgt daraus vermutlich keine Pflicht. Überwachung von Personen gehört nicht zu seinen Tätigkeiten, und personenbezogene Daten kommen in der Arbeit mit überwiegend gemeinfreien Forschungsdaten nur selten vor, sodass ihre Verarbeitung weder Kerntätigkeit noch umfangreich sein dürfte. Kommen Projekte mit vielen personenbezogenen Daten hinzu, ist die Frage neu zu stellen. [7] Art. 37 Abs. 1; [8] S. 7–8
Empfehlung	DHCraft hält diese Prüfung schriftlich fest und aktualisiert sie, wenn ein neuer Projekttyp mit personenbezogenen Daten hinzukommt. Die Prüfung wird außerdem wiederholt, wenn der EDPB seine Leitlinien zu Datenschutzbeauftragten überarbeitet hat. [8] S. 5; [10] S. 3
	Bestellt DHCraft freiwillig eine Datenschutzbeauftragte Person, gelten alle Pflichten der Art. 37 bis 39 DSGVO wie bei einer Pflichtbestellung. Wer über Zwecke und Mittel der Verarbeitung entscheidet, etwa die Geschäftsführung, kann diese Rolle wegen Interessenkonflikts nicht übernehmen. Bei zwei Eigentümern käme daher nur eine externe Person auf Dienstvertrag in Frage. [8] S. 5, 16; [7] Art. 38 Abs. 6, Art. 37 Abs. 6
Empfehlung	Ohne Bestellung trägt die Ansprechperson für Datenschutz nicht den Titel Datenschutzbeauftragte, damit intern und gegenüber der Behörde keine Verwechslung entsteht. [8] S. 6

3 Werkzeuge

Ableitung	DHCraft führt ein Register aller zugelassenen KI-Werkzeuge und Agents mit Einsatzzweck, Hosting-Ort und den Bedingungen zur Weiterverwendung von Daten. [1] S. 11; [3] S. 18
Empfehlung	Agents laden nur Werkzeuge und Erweiterungen aus diesem Register, in festgelegten Versionen. [3] S. 18
Empfehlung	Wo es möglich und nötig ist, nutzt DHCraft selbst betriebene oder lokal gehostete Werkzeuge oder solche vertrauenswürdiger Dritter, die den europäischen Datenschutz einhalten. [1] S. 11

Empfehlung	Ein externer Dienst, an den personenbezogene Daten gehen, ist Auftragsverarbeiter und braucht einen entsprechenden Vertrag. Ein vollständig lokaler Agent braucht diese Prüfung nicht. [5] S. 31–32
Empfehlung	Verträge und Nutzungsbedingungen von Online-Diensten werden bei der Aufnahme ins Register und danach regelmäßig geprüft, unter Beteiligung der Datenschutz-Person. [5] S. 70

4 Datenklassen

DHCraft teilt die Daten, mit denen Agents arbeiten, in vier Klassen ein. Die Einteilung ist eine Ableitung aus den Anforderungen an Vertraulichkeit, Personenbezug und besonders geschützte Daten in den Quellen.

[1] S. 7–8; [5] S. 35

Klasse	Beispiele	Regel für Agents
Offen	eigener Code, veröffentlichte Texte und Daten, gemeinfreie und frei nutzbare Forschungsdaten	Agents arbeiten in einer abgeschotteten Umgebung mit eingeschränktem Netz. Empfehlung [2]
Vertraulich	unveröffentlichte Forschung, Anträge, Gutachten, Kundenmaterial ohne Personenbezug	Nur Dienste, die Eingaben nicht zum Training weiterverwenden, oder lokale Systeme. Empfehlung [1] S. 7–8; [11] S. 2–3
Personenbezogen	Kundendaten, Korrespondenzen, Kontaktdaten	Datenfluss und Rollen sind dokumentiert, die Rechtsgrundlage ist geprüft, und Daten gehen nur an Auftragsverarbeiter. Empfehlung [5] S. 33, 35
Besonders geschützt	Angaben zu Religion, Herkunft, Gesundheit, etwa in Zeitzeugnissen	Zusätzlich eine Ausnahme nach Art. 9 DSGVO, Prüfung einer Datenschutz-Folgenabschätzung, lokale oder vertraglich gesicherte Verarbeitung und menschliche Freigabe jeder Handlung. Ableitung [5] S. 35, 39–40; [4] S. 4

Pflicht	Vor jedem neuen Einsatz mit personenbezogenen Daten wird geprüft, ob er eine eigene Rechtsgrundlage braucht und ob eine Datenschutz-Folgenabschätzung nötig ist. Agents machen eine solche Abschätzung nicht automatisch erforderlich, es kommt auf die Verarbeitung an. [5] S. 35, 41; [4] S. 4

Empfehlung	Ersetzen Agents bisherige Mittel einer Verarbeitung, wird das Verarbeitungsverzeichnis angepasst. [5] S. 36

5 Arbeitsregeln

Kundenprojekte

Empfehlung	Ein Agent erhält nur die Ordner und Konten der aktuellen Aufgabe, nie ein ganzes Postfach, Laufwerk oder eine Kundendatenbank. [3] S. 7; [5] S. 19
Ableitung	Kunden erfahren, welche KI-Werkzeuge und Agents ihr Material bearbeiten und wie es geschützt ist. [1] S. 10
Pflicht (Anbieter)	Ein Agent, den DHCraft baut und der mit Menschen kommuniziert, gibt sich als KI zu erkennen und sagt, in wessen Auftrag er handelt. [6] S. 13

Forschung und Anträge

Empfehlung	Prüfpunkte im Ablauf sorgen dafür, dass ein Mensch methodische Entscheidungen eines Agents bestätigt. [1] S. 7
Vorgabe	Jede Literaturangabe und jede Sachaussage, die ein Agent liefert, wird vor der Verwendung am Original geprüft. Erfundene Angaben in FWF-Anträgen werden sanktioniert, bis hin zur Rückforderung von Fördermitteln. [12]; [1] S. 9
Empfehlung	Für Forschungsschritte, die ein Agent ausführt, werden Prompts, Protokolle, Modellversionen und Parameter aufbewahrt. [1] S. 7; [5] S. 66
Empfehlung	Personenbezogene Daten Dritter gehen nur mit Einwilligung oder anderer Rechtsgrundlage und klarem Zweck an externe KI-Dienste. [1] S. 8
Vorgabe	Bei Begutachtungen bleibt das Urteil beim Menschen, und vertrauliches Material geht nur an gesicherte oder lokale Systeme. Für DFG-Gutachten ist das verbindlich. [11] S. 2–3; [1] S. 9

Ableitung	Code und Methoden werden so genau veröffentlicht, dass andere, auch Agents, die Ergebnisse nachvollziehen können. Unvollständige Methodenbeschreibungen sind der Hauptgrund, warum das misslingt. [13] S. 1

Programmieren

Empfehlung	Coding Agents laufen in einer abgeschotteten Umgebung mit freigegebenen Netzzielen und eigenen, kurzlebigen Zugangsdaten. [2]
Empfehlung	Webseiten, Mails und Dokumente Dritter können versteckte Anweisungen an den Agent enthalten und werden entsprechend behandelt. [5] S. 49; [3] S. 6
Ableitung	Änderungen eines Agents bleiben klein und mit den Prüfenden abgestimmt, weil große und unabgestimmte Pull Requests von Agents häufiger scheitern. [14] S. 1, 2
Ableitung	Wer eine neue Bibliothek oder Methode lernt, nutzt den Agent für Erklärungen und schreibt den Code selbst. Wer ganz delegiert, lernt deutlich weniger und kann Agent-Code später schlechter prüfen. [15] S. 1

6 Freigaben und Protokolle

Empfehlung	Löschen, Deployen, Pushen und das Versenden von Nachrichten brauchen eine menschliche Freigabe. Das Werkzeug erzwingt sie über seine Berechtigungen, eine Anweisung im Prompt reicht nicht. Wann eine Freigabe nötig ist, legen Menschen fest und nicht der Agent. [3] S. 22; [2]
Empfehlung	Kein Agent verbindet ungeprüfte Eingaben, Zugriff auf sensible Daten und selbstständiges Handeln. Wo alle drei zusammenkommen, gibt ein Mensch jede Handlung frei. [5] S. 39–40
Empfehlung	Die Verläufe der Agents werden aufbewahrt und gegen Änderung geschützt, auch gegen Änderung durch den Agent selbst. Da sie sensible Daten enthalten können, gelten für sie dieselben Schutzregeln wie für die Daten. [2]; [3] S. 20

7 Transparenz

Pflicht	Interne Texte und berufliche Korrespondenz, die mit KI entstehen, brauchen keine Kennzeichnung. Ein veröffentlichter Text, der die Öffentlichkeit über Fragen von öffentlichem Interesse informiert, braucht entweder eine redaktionelle Prüfung mit verantwortlicher Person oder eine Kennzeichnung. [6] S. 43
Ableitung	Kommentare, Issues und Nachrichten, die ein Agent an Menschen schreibt, nennen den Agent als Verfasser und DHCraft als Auftraggeber. [6] S. 13, 15
Vorgabe	In FWF-Anträgen wird ein wesentlicher KI-Anteil offengelegt. Eine KI-gestützte Literaturrecherche legt DHCraft ebenfalls offen. Der FWF verlangt das nicht, die EU-Leitlinien zählen sie aber als wesentliche Nutzung. [12]; [1] S. 7

8 Vorfälle

Empfehlung	Jede Agent-Tätigkeit lässt sich sofort stoppen, einschließlich der Netzverbindung und der Verbindung zum LLM-Dienst. [2]
Empfehlung	In unklaren Lagen hält ein Agent an und fragt nach, statt weiterzuarbeiten. [3] S. 20
Empfehlung	DHCraft legt fest, wie es auf einen kompromittierten oder fehlerhaften Agent reagiert, und probt das Vorgehen. [3] S. 19

9 Kompetenz und Einführung

Pflicht	DHCraft ergreift Maßnahmen, die die KI-Kompetenz aller unterstützen, die für DHCraft mit Agents arbeiten, freie Mitarbeitende eingeschlossen. Ein Zertifikat oder ein garantiertes Niveau verlangt das Gesetz nicht. [16] S. 16
Empfehlung	Agents kommen stufenweise zum Einsatz, zuerst für Aufgaben ohne sensible Daten. Zugänge wachsen erst nach Erfahrung. [3] S. 19; [5] S. 55

Empfehlung	Die Eigentümer prüfen diese Governance laufend anhand der Erfahrungen und Vorfälle und passen sie an. [5] S. 53

Festlegungen

Diese Governance nennt keine einzelnen Dienste. Welche Werkzeuge zugelassen sind, mit Einsatzzweck, Hosting-Ort und Stand der Verträge, hält das Werkzeugregister nach Abschnitt 3 fest.

DHCraft arbeitet vor allem mit gemeinfreien und frei nutzbaren Forschungsdaten. Die Regeln für personenbezogene und besonders geschützte Daten gelten für die seltenen Fälle, in denen solche Daten vorkommen.

Beschluss

Die Eigentümer von Digital Humanities Craft beschließen diese Governance in der Version 1.0.

Datum des Beschlusses: _____

Unterschrift: _____ _____

Annahmen und offene Punkte

Die Angaben zu Größe, Tätigkeit und Datenlage von DHCraft stammen von den Eigentümern, nicht aus der Wissensbasis.

Die Einschätzung zur Datenschutzbeauftragten Person stützt sich auf Gesetzestexte und Leitlinien von 2016 und 2017, die als Ausnahme vom Zeitfenster 2026 in die Wissensbasis aufgenommen wurden. Sie ist keine Rechtsberatung, und wo die Grauzone bei „umfangreich“ berührt ist, sollte eine Fachperson die schriftliche Prüfung gegenlesen.

Österreich hat die Behörden für den AI Act noch nicht benannt. Sobald das geschieht, ist die Governance auf deren Vorgaben zu prüfen.

Quellen

Seitenangaben beziehen sich auf die Seite der PDF-Datei der Quelle. Die Originale und je eine Zusammenfassung liegen in der Wissensbasis unter sources/.

[1] European Commission, DG Research and Innovation. Living guidelines on the responsible use of generative AI in research, fourth version. 2026-10-15. research-and-innovation.ec.europa.eu

[2] National Cyber Security Centre (UK). Managing the cyber risk of agentic AI. 2026-08-20. ncsc.gov.uk

[3] ASD's ACSC, CISA, NSA, Canadian Centre for Cyber Security, NCSC-NZ, NCSC-UK. Careful adoption of agentic AI services. 2026-05-01. ncsc.govt.nz

[4] Österreichische Datenschutzbehörde (DSB). Newsletter Nr. 1/2026, article Updates zu KI und Datenschutz. 2026 (issue 1/2026). dsb.gv.at

[5] Agencia Española de Protección de Datos (AEPD). Agentic Artificial Intelligence from the perspective of data protection, V1.1. 2026-02. aepd.es

[6] European Commission. Guidelines on the implementation of the transparency obligations for certain AI systems under Article 50 of Regulation (EU) 2024/1689. 2026-07-20. digital-strategy.ec.europa.eu

[7] European Parliament and Council. Regulation (EU) 2016/679 (GDPR), Recital 97 and Articles 37 to 39 (excerpt). 2016-04-27 (Ausnahme vom Zeitfenster 2026). publications.europa.eu

[8] Article 29 Data Protection Working Party. Guidelines on Data Protection Officers ('DPOs'), WP 243 rev.01. 2017-04-05 (Ausnahme vom Zeitfenster 2026). ec.europa.eu

[9] Bundeskanzleramt, RIS. Datenschutzgesetz (DSG), provisions on the data protection officer (excerpt). 2026-11-05 (konsolidierte Fassung, Ausnahme vom Zeitfenster 2026). ris.bka.gv.at

[10] European Data Protection Board (EDPB). EDPB Work Programme 2026-2027. 2026-02-11. edpb.europa.eu

[11] Deutsche Forschungsgemeinschaft (DFG). Leitlinie zur Nutzung von Künstlicher Intelligenz in der Begutachtung (DFG-Vordruck 4.04). 2026-03. dfg.de

[12] FWF Austrian Science Fund. AI in Funding Applications: Transparency and Accountability. 2026-07-07. fwf.ac.at

[13] ETH Zurich, TU Wien and University of Basel, via arXiv. Read the Paper, Write the Code: Agentic Reproduction of Social-Science Results (Preprint, v2). 2026-09-29. arxiv.org

[14] Drexel University and Missouri S&T, via arXiv. Where Do AI Coding Agents Fail? An Empirical Study of Failed Agentic Pull Requests in GitHub (Preprint). 2026-01-21. arxiv.org

[15] Anthropic Fellows Program, via arXiv. How AI Impacts Skill Formation (Preprint, v2). 2026-02-01. arxiv.org

[16] European Parliament and Council. Regulation (EU) 2026/1744 amending Regulation (EU) 2024/1689 (Digital Omnibus on AI). 2026-07-08 (OJ L of 24.7.2026). eur-lex.europa.eu